

Capstone Project

Full-Scope Vulnerability Assessment & Penetration Testing (VAPT)

1. Overview

A full-scope Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted against a HackTheBox virtual machine to simulate a real-world internal security assessment. The objective of this engagement was to identify security weaknesses, exploit confirmed vulnerabilities, assess their real-world impact, and provide validated remediation recommendations.

The assessment strictly followed the **Penetration Testing Execution Standard (PTES)** framework, covering reconnaissance, exploitation, post-exploitation, remediation, and validation phases.

2. Test Environment

Component	Details
Attacker Operating System	Kali Linux
Target System	HackTheBox Virtual Machine
Target IP Address	192.168.132.129
Assessment Type	Internal Network Penetration Test
Tools Used	Metasploit Framework, Burp Suite, OpenVAS, Google Docs

3. Scope & Methodology

The engagement followed the **PTES methodology**, ensuring a structured and repeatable approach:

- Reconnaissance
- Exploitation
- Post-Exploitation
- Remediation

5. Validation

All activities were conducted in a controlled lab environment for educational and assessment purposes.

4. Executive Summary

This penetration testing engagement evaluated the security posture of an internal system by simulating a realistic cyberattack scenario. A **critical remote code execution vulnerability** was identified and successfully exploited, resulting in **full system compromise**.

The root cause of the compromise was outdated and vulnerable software running on exposed services. Additional weaknesses related to API input handling and insufficient access controls were also identified, increasing the overall attack surface.

Remediation actions were implemented and validated through follow-up vulnerability scans, confirming a significant reduction in risk exposure.

5. Attack Timeline & Findings

5.1 Reconnaissance Phase

Network scanning and service enumeration revealed multiple open services on the target host (192.168.132.129). An FTP service was identified running an outdated version of **VSFTPD (v2.3.4)**, known to contain a malicious backdoor vulnerability.

Key findings:

- Open FTP and HTTP services
 - Outdated VSFTPD service vulnerable to remote exploitation
-

5.2 Exploitation Phase

A publicly available Metasploit module was leveraged to exploit the identified vulnerability:

- **Exploit Used:** `exploit/unix/ftp/vsftpd_234_backdoor`
- **Impact:** Remote Code Execution (RCE)

Successful exploitation resulted in unauthenticated shell access to the target system, demonstrating the severity of the vulnerability.

5.3 Post-Exploitation Phase

Following successful exploitation, the attacker was able to:

- Confirm system-level access
- Identify privilege context
- Access sensitive system files

This phase validated that the compromised service could lead to **complete system takeover**, posing a critical security risk.

5.4 API Security Testing

Using **Burp Suite**, API traffic was analyzed to identify additional weaknesses. The following issues were observed:

- Weak input validation mechanisms
- Absence of strong authentication controls
- Increased susceptibility to injection and manipulation attacks

While not exploited further, these findings significantly increase the likelihood of future compromise if left unaddressed.

5.5 Validation Phase

OpenVAS vulnerability scans were conducted:

- **Before remediation** to establish baseline risk
- **After remediation** to validate risk reduction

Post-remediation scans confirmed the elimination of the critical FTP vulnerability and an overall improvement in the system’s security posture.

6. Vulnerability Summary

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-30 15:00:00	192.168.132.129	VSFTPD 2.3.4 Remote Code Execution	Exploitation

7. Remediation Recommendations

The following remediation steps were implemented and validated:

- Upgrade or patch VSFTPD to a secure, supported version
 - Disable unused or unnecessary network services
 - Implement strict input validation for APIs
 - Enforce least-privilege access controls
 - Establish regular vulnerability scanning and patch management processes
-

8. Rescan Results (OpenVAS)

Post-remediation OpenVAS scans confirmed:

- Removal of the critical FTP vulnerability
 - Reduction in overall vulnerability severity ratings
 - Improved system hardening and reduced attack surface
-

9. Non-Technical Executive Briefing

This assessment simulated a real-world cyberattack against an internal system to evaluate its defensive capabilities. A critical weakness was identified that allowed attackers to gain unauthorized remote access, leading to full system compromise.

The primary cause was outdated software and insufficient security controls. Additional weaknesses related to API input validation further increased the system's exposure to attack.

Corrective actions, including patching, access restriction, and configuration hardening, were applied. Follow-up scans verified that the most severe risks were successfully mitigated.

This engagement underscores the importance of proactive security testing, timely patching, and enforcing least-privilege access to reduce the likelihood of unauthorized access and potential business impact.
